

SGSI-UNCP

Plantilla de Informe de Auditoría Interna del SGSI

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Plantilla de Informe de Auditoría Interna del SGSI
 - 1.1 Resumen Ejecutivo
 - 1.2 Detalle de la Auditoría
 - 1.3 Resultados por Cláusula ISO 27001
 - 1.4 Resultados por Dominio de Control (Anexo A)
 - 1.5 Detalle de Hallazgos
 - 1.6 Conclusiones y Recomendaciones
 - 1.7 Distribución del Informe

1. Plantilla de Informe de Auditoría Interna del SGSI

Organización: Universidad Nacional del Centro del Perú (UNCP) **Auditoría ID:** AUD-2026-001 **Tipo de Auditoría:** Interna **Fecha de Auditoría:** 20/05/2026 – 22/05/2026 **Fecha del Informe:** 29/05/2026

1.1. Resumen Ejecutivo

Se realizó la primera auditoría interna del SGSI-UNCP durante los días 20 al 22 de mayo de 2026, cubriendo las cláusulas 4 a 10 de la ISO/IEC 27001:2022 y los 93 controles del Anexo A declarados en la D-SGSI-05 (SoA). Se identificaron 11 hallazgos: 2 fortalezas, 2 no conformidades mayores, 4 no conformidades menores y 3 oportunidades de mejora. El dictamen general es **Favorable con observaciones**, recomendando avanzar hacia la certificación una vez cerradas las NC mayores.

1.1.1. Metodología Aplicada

La auditoría se realizó siguiendo la metodología definida en **P-SGSI-09** (Metodología de Auditoría Basada en Riesgos), utilizando las técnicas de recolección planificadas en el Plan de Auditoría **AUD-2026-001**: entrevistas con 12 responsables, revisión documental de 18 documentos SGSI, y verificación in situ del Data Center Huanca- y la sala de servidores de la Facultad de Ingeniería de Sistemas.

1.1.2. Resultados Generales

Indicador	Valor
Total de hallazgos	11
Fortalezas identificadas	2
No Conformidades Mayores	2
No Conformidades Menores	4
Oportunidades de Mejora	3
Dictamen General	Favorable con observaciones

1.2. Detalle de la Auditoría

1.2.1. Equipo Auditor

Rol	Nombre
Auditor Líder	Mg. Carlos Ramos Quispe
Auditor Técnico	Ing. María Rojas Llanos
Auditor(es) de Soporte	Bach. Luis Torres Miranda

1.2.2. Áreas y Procesos Auditados

- **Rectorado:** Compromiso de liderazgo (Cl. 5.1), asignación de recursos.
- **OTI:** Gestión de activos (A.8), seguridad en redes (A.8.20–8.22), gestión de cambios (P-SGSI-04), gestión de incidentes (P-SGSI-02).
- **Oficina de Seguridad y Confianza Digital:** Política SGSI (D-SGSI-03), SoA (D-SGSI-05), riesgo (D-SGSI-04), plan de capacitación (P-SGSI-08).
- **Abastecimiento:** Gestión de proveedores (P-SGSI-06), contratos con cláusulas de seguridad.
- **Recursos Humanos:** Inducción en seguridad, confidencialidad del personal.
- **Data Center (Huancayo):** Controles físicos (A.7), CCTV, control de acceso biométrico, extintores, PDU.

1.2.3. Criterios de Auditoría Utilizados

- ISO/IEC 27001:2022 – Cláusulas 4 a 10
- Anexo A – Controles según D-SGSI-05 (SoA)
- Políticas y procedimientos del SGSI-UNCP
- Ley N° 29733 / D.S. 016-2024-JUS / D.L. 1412

1.3. Resultados por Cláusula ISO 27001

Cláusula	Evaluación	Hallazgos Clave
Cl. 4 – Contexto	Adecuado	Contexto estratégico documentado (D-SGSI-01); partes interesadas identificadas y sus requisitos mapeados Acta de compromiso firmada (ACT-SGSI-01); política publicada y comunicada en intranet SoA completo (D-SGSI-05) pero no se evidencian todos los planes de tratamiento de riesgos firmados Competencia del personal documentada; plan de capacitación 2026 en ejecución Controles técnicos implementados parcialmente; falta evidencia de pruebas de DRP (P-SGSI-05) No se realizó la primera revisión por la dirección (Cl. 9.3); falta programa de auditoría interna previo No conformidades anteriores sin cierre documentado; falta evidencia de acciones correctivas
Cl. 5 – Liderazgo	Adecuado	
Cl. 6 – Planificación	Parcial	
Cl. 7 – Soporte	Adecuado	
Cl. 8 – Operación	Parcial	
Cl. 9 – Evaluación	Inadecuado	
Cl. 10 – Mejora	Parcial	

1.4. Resultados por Dominio de Control (Anexo A)

Dominio	Controles evaluados	Hallazgos	Evaluación General
A.5 – Organizacionales	28	1 NC menor (A.5.27 – aprendizaje de incidentes)	Adecuado
A.6 – Personas	6	1 NC menor (A.6.3 – concientización no completa en administrativos)	Adecuado
A.7 – Físicos	13	1 NC mayor (A.7.8 – falta inventario de equipos en sala servidores auxiliar)	Parcial
A.8 – Tecnológicos	46	1 NC mayor (A.8.16 – monitoreo insuficiente en servicios cloud), 2 NC menores	Parcial

1.5. Detalle de Hallazgos

1.5.1. Fortalezas

ID	Referencia	Descripción de la Fortaleza
F01	Cl. 5 / A.5.1	El Comité de Gobierno Digital (CGD) sesiona mensualmente con agenda de seguridad informática; el Rector Dr. Amador Vilcatoma preside personalmente las revisiones
F02	A.8.9	Gestión de configuración de activos mediante CMDB actualizada con 24 activos críticos inventariados en R-SGSI-01

1.5.2. No Conformidades

ID	Referencia	Descripción del Hallazgo (Evidencia Objetiva)	Clasificación	Requisito Incumplido	Acción Correctiva Propuesta	Plazo
NC-01	A.7.8	En la inspección a la sala de servidores de la Facultad de Ingeniería de Sistemas se encontraron 3 equipos (2 switches, 1 servidor) no registrados en el inventario de activos R-SGSI-01. No tienen código de activo ni custodio asignado.	Mayor	ISO 27001:2022 A.7.8 – “Los equipos deben ser inventariados”	Realizar inventario físico completo de todas las salas de servidores auxiliares (Facultades) en 30 días; actualizar R-SGSI-01	30/06/2026
NC-02	A.8.16	No se evidencian alertas de monitoreo configuradas para los buckets de respaldo en Huawei Cloud. El último acceso registrado a los logs del CBR data de 4 meses atrás.	Mayor	ISO 27001:2022 A.8.16 – “Las actividades de monitoreo deben ser registradas y revisadas”	Configurar alertas de monitoreo continuo en Huawei Cloud CBR; programar revisión semanal de logs	30/06/2026
NC-03	A.5.27	Tras el incidente de phishing reportado en abril 2026 (P-SGSI-02), no se documentaron las lecciones aprendidas ni se actualizó el plan de capacitación	Menor	ISO 27001:2022 A.5.27 – “El conocimiento adquirido debe ser utilizado para mejorar”	Elaborar informe de lecciones aprendidas del incidente de phishing; actualizar P-SGSI-08 con el escenario	15/07/2026

ID	Referencia	Descripción del Hallazgo (Evidencia Objetiva)	Clasificación	Requisito Incumplido	Acción Correctiva Propuesta	Plazo
NC-04	A.6.3	El 62 % del personal administrativo de las facultades no ha completado el módulo de concientización en seguridad (datos del LMS corporativo, corte 15/05/2026)	Menor	ISO 27001:2022 A.6.3 – “El personal debe recibir capacitación en seguridad”	Extender plazo del programa de concientización; enviar recordatorios semanales; reportar avance al CGD	31/07/2026
NC-05	Cl. 9.3	No se ha realizado la primera revisión del SGSI por la dirección a la fecha de la auditoría, a pesar de que el cronograma del PGTD la programaba para marzo 2026	Menor	ISO 27001:2022 Cl. 9.3 – “La dirección debe revisar el SGSI a intervalos planificados”	Realizar la Revisión por la Dirección antes del 31/07/2026; documentar acta con entradas y salidas de revisión	31/07/2026
NC-06	Cl. 10.1	No se ha documentado evidencia del seguimiento a las NC de la auditoría interna anterior (no hubo auditoría previa). No existe un registro formal de acciones correctivas.	Menor	ISO 27001:2022 Cl. 10.1 – “Las no conformidades deben ser documentadas y revisadas”	Implementar registro de acciones correctivas en la herramienta de gestión documental; asignar responsables	30/08/2026

1.5.3. Oportunidades de Mejora

ID	Referencia	Descripción	Sugerencia
OM-01	A.5.32	Los derechos de propiedad intelectual del software desarrollado por terceros no están explícitamente asignados a la UNCP en todos los contratos de desarrollo	Incluir cláusula estándar de propiedad intelectual en todos los contratos de desarrollo de software, revisada por Asesoría Jurídica
OM-02	A.8.24	No se utiliza cifrado a nivel de base de datos para los campos sensibles (DNI, domicilio) en el sistema GESDOC	Evaluar e implementar cifrado a nivel de columna (AES-256) para datos personales en GESDOC, alineado a la Ley N° 29733

ID	Referencia	Descripción	Sugerencia
OM-03	A.7.10	La sala de servidores de la Facultad de Ingeniería de Sistemas no cuenta con sistema de detección de inundación ni sensor de humedad	Instalar sensores de humedad y un sistema de detección de inundación en todas las salas de servidores antes de la próxima auditoría

1.6. Conclusiones y Recomendaciones

1.6.1. Conclusión General

El SGSI de la UNCP, basado en la muestra auditada, es: - [] Totalmente conforme a ISO/IEC 27001:2022 - [x] Parcialmente conforme (requiere acciones correctivas antes de certificación) - [] No conforme (requiere mejoras sustanciales)

1.6.2. Recomendaciones

1. **Prioridad Alta – Cerrar NC mayores:** Completar el inventario físico de activos en todas las salas de servidores auxiliares (NC-01) y configurar el monitoreo continuo de servicios cloud (NC-02) antes del 30/06/2026.
2. **Prioridad Media – Revisión por la Dirección:** Programar y ejecutar la Revisión por la Dirección (Cl. 9.3) antes del 31/07/2026 para cumplir el estándar.
3. **Prioridad Media – Programa de concientización:** Reforzar el programa de concientización en seguridad para personal administrativo de facultades y medir la efectividad con indicadores (phishing click rate < 10 %).

1.6.3. Próximos Pasos

Acción	Responsable	Fecha Límite
Enviar plan de acciones correctivas	Oficial de Seguridad	15/06/2026
Implementar correcciones NC-01 y NC-02	Jefe de OTI	30/06/2026
Implementar correcciones NC-03 a NC-06	Oficial de Seguridad	31/08/2026
Verificar cierre de hallazgos	Auditor Líder	30/09/2026

1.7. Distribución del Informe

Copia	Destinatario
01	Rector (Presidente del Comité de Gobierno Digital)
02	Oficial de Seguridad y Confianza Digital
03	Archivo del SGSI

Firmas:

Rol	Nombre	Firma
Auditor Líder	Mg. Carlos Ramos Quispe	
Auditor Técnico	Ing. María Rojas Llanos	
Oficial de Seguridad (Recibido)	Ing. Luis Castillo Gutierrez	

Anexos: - Anexo 1: Lista de Chequeo completa - Anexo 2: Evidencias recopiladas (índice) - Anexo 3: Plan de Auditoría ejecutado